# NHI Discovery: posture page testing sheet (28/10/2026), status

The findings in the sheet sorted into: fixed now, not a bug, and not fixed because a change now could break the website or needs production data. Rows the sheet marks NIL / "don't know where to check" (score-by-area counts, checks filters, history, roles use, activity, findings filters, #19-36, #42-53, #57-73) are verification tasks, not findings: the answer for each is under "How to verify" on page 2. Prepared 11/11/2026 from branch ccr-a99e60a2-l35hoj.

## 1. Fixed now

| # | Finding | What was wrong | What was done | Confidence |
|---|---|---|---|---|
| 1 | Fleet score: dashboard shows an approximate value | The dashboard rounded the score to a whole number; Posture shows one decimal. | The dashboard shows the exact score to one decimal, the same number as Posture. | Certain |
| - | No rate limiting over the API | Only sign-in, posture and remediation calls were limited. | Every API call is limited per client address: a burst of 200, then 25 a second; beyond that 429 with Retry-After. Tested: 260 rapid requests gave 200 x200 and 60 x429. Note: 20 rapid requests still succeed by design - one dashboard page sends about 20 at once. | Certain |
| - | Database column names leaked via sort_by errors | The error listed every sortable field. | Identities and credentials now answer "Invalid sort_by: this field cannot be sorted on" without the list. | Certain |
| - | /api/v2 answers 502 through nginx | nginx forwarded every /api/ path to the backend. | Only /api/v1/ is forwarded; any other /api/ path gets a 404 JSON from nginx. Tested in nginx: /api/v2/... 404, /api/v1/health 200. | Certain |
| 13 | Wildcard resource check: "The posture catalog has no fix text" | The check drawer showed only the short fix label, which this rule lacks. | It falls back to the rule's remediation text, and otherwise points to Remediation, which now has steps for every finding. | Certain |

## 2. Not a bug

| # | Finding | Why | Evidence |
|---|---|---|---|
| - | Scope (region) change without verification | Changing an account's regions is an admin action, recorded in the audit log. Other roles are refused. | Tested: PUT regions as viewer 403, as analyst 403. |
| - | JWT token misuse | A stolen session token works until it expires, as in any web app. Sessions are 15 minutes, idle 1 hour, at most 12 hours; sign-out ends them. | Earlier security round. |
| - | Role and username inside the JWT | Signed, not secret: the server checks the signature and re-reads the role from the database on each call. | - |
| 54 | "Why this score" wrong for a score of 0 | Fixed earlier: it now says the checks cost all 100 points (with the real total). | Earlier round. |

## 3. Not fixed now: risky, or needs production data / the scanners

| # | Finding | What is behind it | Why not now (risk) |
|---|---|---|---|
| - | Database name inside the JWT | The discovery scan service reads db_name from the token. Our API already ignores it. | Removing it stops scanning. The scan service must first read the tenant from the registry; then the claim can go. |
| 37 | Deleted account still in "By account", average wrong | The by-account means come from the posture engine's snapshot, which still holds the removed account's identities. | Filtering them in the console would make the list disagree with the fleet score the engine computed. The engine must drop a removed account's identities; then both fix themselves. |
| 7-16, 12 | Quick wins / owner description not changing after a tag is fixed | These change only after the next discovery scan and posture scan read the new tag. | Nothing to change in the console; re-test after a full scan (Sync, then Run checks again). |
| 11 | Owner tag count: "not proper sanitization of characters" | The sheet does not say which input or characters. | Need the exact value tried and where it showed, to reproduce. |
| - | Integration bypass with a fake AWS account | Marked "ongoing" in the sheet. | A connection only succeeds after AssumeRole with the tenant's External ID, and the first account needs adapID's approval. |
| - | Scan pop-up counts after modifications | The pop-up counts what the scan reported. | Needs the scan id and the changes made, to compare with the scanner. |
| 69 | Credentials card: usage, date, privilege missing | Those fields come from CloudTrail; locally and in some tenants CloudTrail data is not available, and the card says unknown. | Needs the tenant and identity to check whether the activity store had data. |
| 74 | UI screen visibility issue | No detail in the sheet. | Need a screenshot and the screen size. |

## How to verify the NIL rows (score by area, counts, filters)

Score by security area: the average of the identities' pillar scores; the description counts are the failed and total checks of that pillar across scored identities. Identities by score: healthy 80-100, fair 60-79, poor 40-59, critical below 40 (Posture → Identities, filter by band, the counts match). By category / account: the mean score of the identities in that category or account. Checks tab filters: All = every check of the identity, Failed / Passed by result, pillar dropdown narrows to that pillar. History: one point per posture scan. Each of these can be checked by fixing one failed check on one identity, running a scan, and watching the identity's score rise by that check's penalty points.